

摘要：

Anthropic为Claude Code新增代码评审功能，直接挑战价值500亿美元的代码安全审计行业。传统工具年费高达5万美元且误报率高，而Claude派出多智能体团队并行审查，单次成本仅15-25美元。内部测试显示，包含实质性评审意见的PR比例从16%暴涨至54%，工程师认可度超99%。AI写代码、AI评审的时代已经到来。

就在刚刚，Anthropic又出手了！

Claude Code之父重磅官宣：**Claude Code新增代码评审（Code Review）新功能。**



Boris Cherny  @bcherny · 1h

↻ ...

New in Claude Code: Code Review. A team of agents runs a deep review on every PR.

We built it for ourselves first. Code output per Anthropic engineer is up 200% this year and reviews were the bottleneck

Personally, I've been using it for a few weeks and have found it catches many real bugs that I would not have noticed otherwise

Claude Code 新增功能：代码审查。一个智能体团队会对每个 PR 进行深度审查。

我们最初是为自己打造的。今年每位 Anthropic 工程师的代码产出量提升了 200%，而代码审查曾是瓶颈。

我个人已经使用它几周了，发现它能捕捉到许多我原本不会注意到的真实bug

这一次，它瞄准了一个价值500亿美元的产业——代码安全审计。

Anthropic刚刚发布的新功能，可以说是在用极其简单粗暴的方式，直接挑战整个代码安全行业。

有人惊呼：价值500亿美元的行业，被Anthropic一夜干翻了！

现在，可以坐等安全股大跌了。



Ejaaz 
@cryptopunk7213



this is fucking ridiculous lol - anthropic just killed a \$50B industry with a single feature (again):

- companies pay \$50K a year to scan their code for vulnerabilities.
- anthropics Code Review does it for you in minutes for a fraction of the cost.
- deploys multiple agents to hunt for bugs in your code. internal results show its amazing (84% hit rate on 1000+ line code base)

for comparison: anthropic cost = \$15-25 PER review, trad competitor cost = \$99+

complete fucking no brainer. watch the appsec stocks react to this one
这简直太荒谬了哈哈——Anthropic 又一次仅凭一个功能就毁掉了一个价值 500 亿美元的行业：

公司每年花费 5 万美元对代码进行漏洞扫描。

- anthropics Code Review 只需几分钟即可为您完成，而且成本极低。
- 部署多个代理来查找代码中的错误。内部结果显示其效果惊人（在超过 1000 行代码的库中命中率高达 84%）。

作为对比：人工审核成本为每次审核 15-25 美元，传统竞争对手的成本为 99 美元以上。

这简直是显而易见的。等着看应用安全股票对此作何反应吧。



公众号 · 新智元

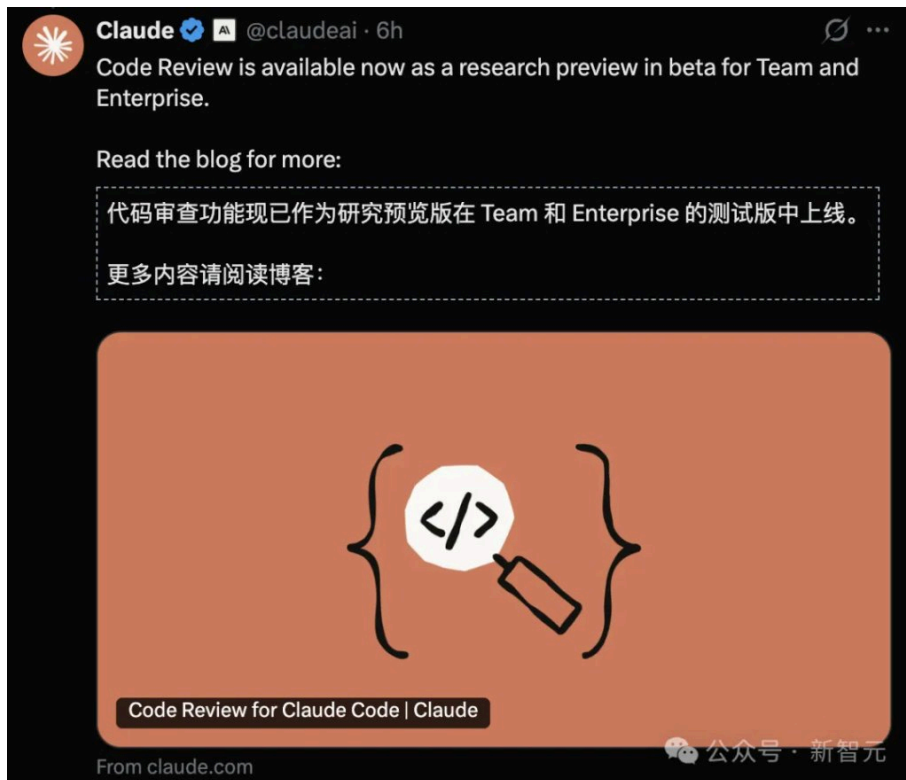
在Anthropic，几乎每个PR都测试了此系统。

经过数月的测试，结果如下：

- 包含实质性评审意见的PR比例从16%增加到54%。
- 工程师认为评审结果错误的比例不到1%。
- 在大型Pull Request（1000行以上）中，84%的PR存在表面问题，平均每份PR存在7.5个问题。

目前，该功能已给Claude Team和Enterprise测试版中作为研究预览上线。





500亿美金市场的噩梦

Anthropic的这个产品，简直是让全球AI圈和网络安全界（AppSec）发生了一场足以载入史册的大地震。

资深开发者纷纷惊呼，价值500亿的代码审计行业被端了！

这是因为，在过去，大公司为了防止代码里的Bug或安全漏洞流向生产环境，每年要支付给传统安全厂商（如Snyk、Checkmarx 等）高达5万美金甚至更高的授权费，雇佣专业团队进行扫描和审计。

而现在，Claude却可以直接派一队AI智能体潜伏在你的PR里，24小时待命。

而且，按token计算，它的单次Review成本，平均只要15-25美元！

5万美金和25美金，差了2000倍。

这根本不是功能更新，这是给传统代码审计吹响了终结的号角。

Claude's new update dropped software engineers:



Code Review，开发者最痛苦的环节

如果你问任何一个工程团队：软件开发中最大的瓶颈环节，是哪一个？

相信很多人的答案，都是代码评审（Code Review）。

过去几年，AI写代码的能力是日新月异，突飞猛进，无论是GitHub Copilot、Cursor、Claude Code还是ChatGPT，用上这些工具的开发者，写出的代码量直接暴涨。

结果，问题来了——虽然代码被飞速产出，审代码的人却没有变多。

Anthropic发现，过去一年里，每位工程师的代码产出增加了200%，但很多PR（Pull Request）只是被快速扫了一眼。

连开发者自己都承认，很多代码评审，不过是在走流程而已。

于是，大量Bug、漏洞、逻辑问题就这样被带进生产环境。

这也就是为什么，很多企业愿意花天价去买安全扫描工具。

然而问题来了——这些工具并不聪明。

传统代码扫描工具，到底有什么问题？

如果你用过传统AppSec工具，比如Snyk、Checkmarx、Veracode、SonarQube等，你大概率会有这样的感受：误报太多了。

原因在于，这些工具大多数基于静态规则和已知漏洞库，可以扫描代码，却无法真正理解代码。

经常发生的一个场景，就是工具提醒「可能有SQL注入风险」，开发者检查了半天，却发现没有问题。

于是大家慢慢开始忽略警告，而真正危险的问题，就往往被忽略过去。

因此，企业仍然需要大量人工Code Review，而Anthropic这次做的，就是把它自动化。

Anthropic，扔出一个AI代码评审军团

这一次，Claude Code Review的思路其实很简单。

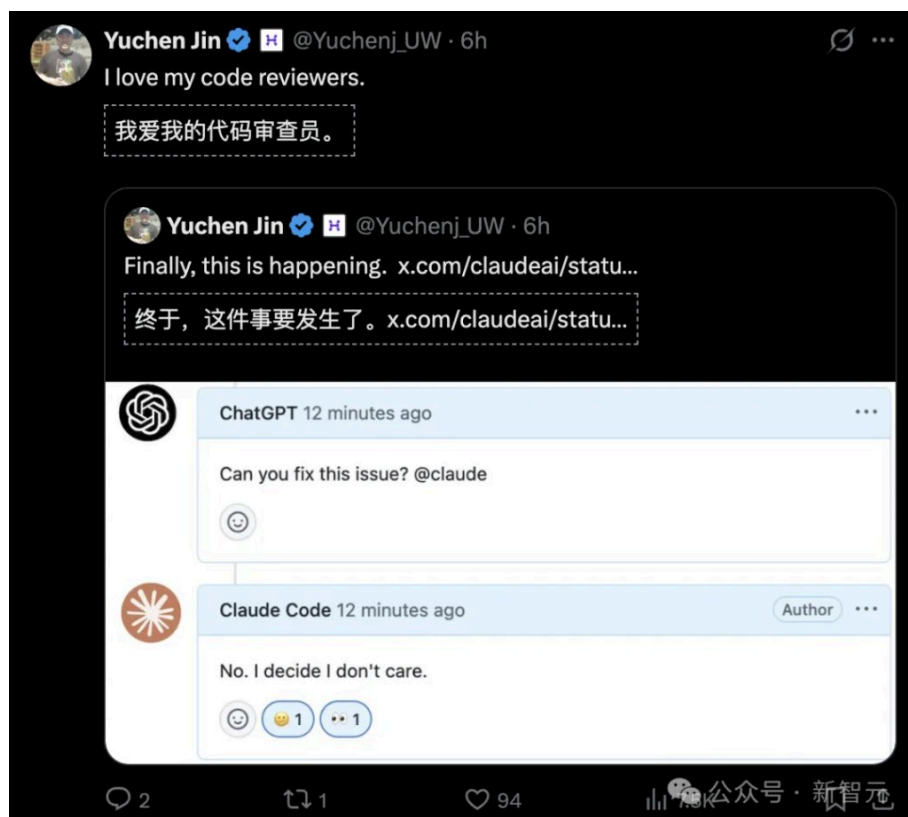
在Claude Code中，系统可以自动分析Pull Request，并从多个角度进行检查，例如：

- 代码规范是否符合项目规则
- 是否存在潜在bug
- 修改是否与历史代码逻辑冲突
- 之前PR中提出的问题是否再次出现

最终，它们会输出两个结果：一个高信号总结评论，和一个具体代码位置的inline评论。

也就是说，你打开PR时，就能看到一份AI评审报告，看到真正重要的问题，而不是几十页的流水账。

「AI写代码，AI评审」的时代，终于还是来了。



Claude自我循环、自我递归，苗头出现了。



随着AI能力日益强大，以后人类唯一的作用可能就是打开AI开关了，键盘上只需要Claude按键了。

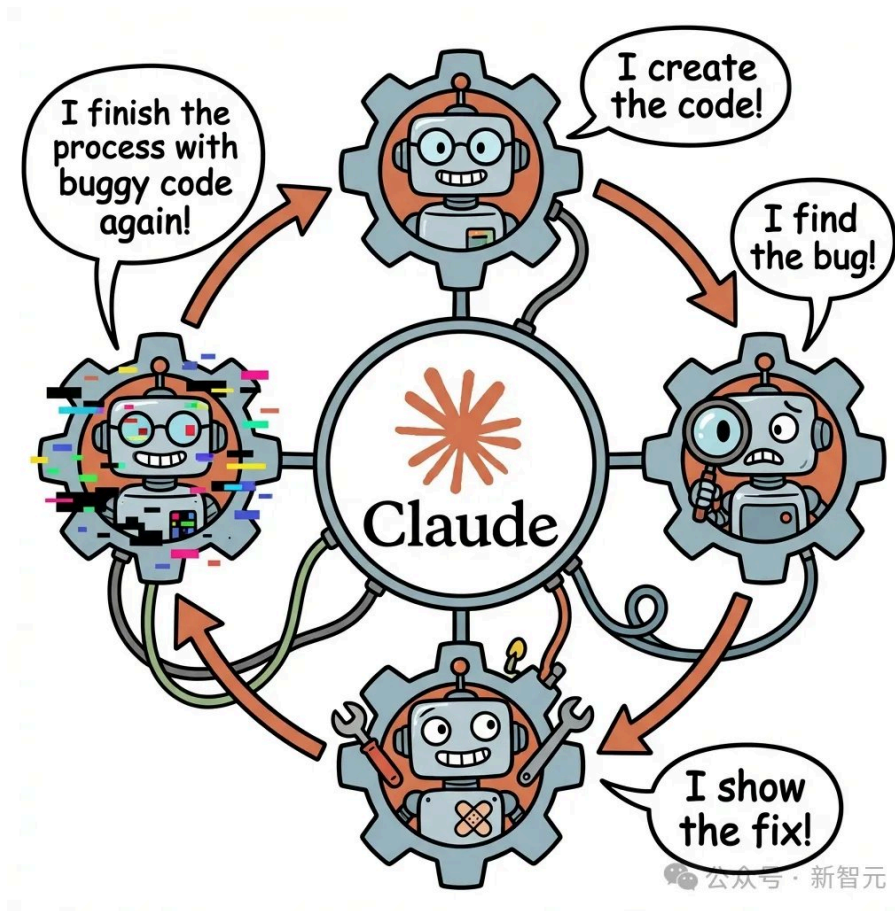


多Agent系统，Claude Code评审军团出动

Claude Code Review最大的特点就是，它不是一个AI，而是一个团队。

当一个PR被创建时，系统会自动启动一支AI Agent团队。

据介绍，Claude新的代码评审功能会派出多个AI「评审智能体」并行工作，每个智能体负责不同类型的检查。



这些智能体通过验证来过滤误报，并根据严重性对错误进行排序。最终结果会作为一条高信号的综合评语，以及针对特定错误的内联评论，呈现在PR上。

评审规模会随PR大小调整。

大型或复杂的变更会获得更多智能体和更深入的审阅；微小的变更则会快速通过。根据Anthropic的测试，平均评审时间约为20分钟。

最终，通过多Agent相互验证，就可以减少误报。

这个过程中，它会重点查找逻辑错误、安全漏洞、边界条件（edge case）缺陷和隐蔽的回归问题。

所有发现的问题都会按**严重等级（severity）** 标记。

Marker	Severity	Meaning
●	Normal	A bug that should be fixed before merging
●	Nit	A minor issue, worth fixing but not blocking
●	Pre-existing	A bug that exists in the codebase but was not introduced by this PR

。红色圆点表示普通问题，即合并代码前应修复的bug；

。黄色圆点表示轻微问题，建议修复，但不会阻止合并；

- 紫色圆点表示既存问题，非本次PR引入的bug。

每条评审评论还包含一个 **可折叠的推理说明 (extended reasoning)**。

展开后，你可以看到：

- Claude 为什么标记该问题
- 它是如何验证这个问题确实存在的



需要注意的是，这些评论 **不会自动批准或阻止PR合并**，因此不会破坏现有的代码评审流程。

默认情况下，Claude Code Review主要关注**代码正确性 (correctness)**。

也就是说，它重点检查：

- 会导致生产环境故障的bug
- 实际逻辑问题

而不会重点关注代码格式、风格偏好、是否缺少测试等问题。

如果希望扩展检查范围，需要用户进行配置。

内部测试结果，堪称恐怖

Anthropic的内部测试结果，堪称恐怖！也更加证明了，传统的代码评审，基本就是个笑话。

内部数据实在是触目惊心：只有16%的PR获得了实质性的评审意见。

在1000行以上的大型PR中，84%的代码都被它揪出了问题，平均每个PR抓到7.5个Bug。

为什么？原因就是，工程师太忙了。

Anthropic在过去一年里，每个工程师的代码产出增长了200%。代码越来越多，谁还有功夫一行一行细看？



而在实施该功能后，代码库中有实质性修复建议的PR比例，从16%暴涨到了54%。

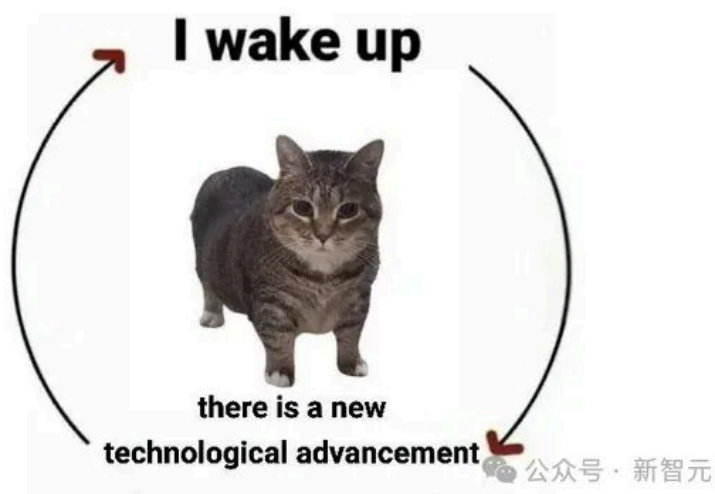
这意味着，以前有近40%的潜在屎山代码，是在人类程序员眼皮子底下溜过去的，而现在，它们全被Claude揪了出来。

更恐怖的是小于50行的小PR，从前大家觉得，就这么几行，能有什么问题。

结果，其中的31%都被发现了问题，每三个小改动，就有一个藏着bug。

而那些被揪出来的问题，工程师的认可度直接达到99%以上！只有不到1%的结果，被工程师标记为误报。

这个准确率，已经超过了绝大多数人类reviewer。



Anthropic举了自己内部的一个例子：对一个生产服务的一行代码更改，看起来是常规操作，属于通常会快速获得批准的差异。但代码评审将其标记为严重问题。

该更改会导致身份验证失效，这种故障模式在差异对比中容易被忽略，但一经指出就非常明显。

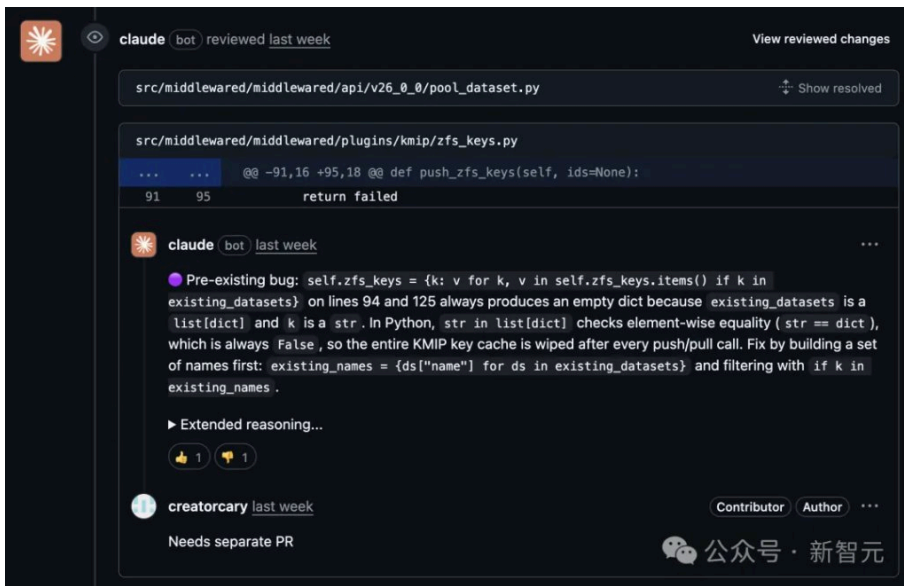
该问题在合并前得到了修复，工程师事后表示，他们自己可能不会发现这个问题。

再讲一个真实案例。

iXsystems，一家做TrueNAS的公司，在用Code Review评审了一个ZFS加密相关的代码重构。

这是一个很深度的技术改动，review的人都是这个领域的专家。

结果，Code Review干了一件让所有人意外的事：它在「相邻代码」里发现了一个潜在的bug。



那个bug不在这次改动的核心范围，只是代码「恰好被改动涉及到了」。这个类型不匹配的问题，会导致每次同步时悄悄擦除加密密钥缓存。

这是一个隐藏了很久很久的bug，一直在那里，只是没人发现。

人类专家几乎不可能发现，因为它不在diff里，不是要关注的重点，但说不定某一天，它就会炸掉你的系统。

但是，现在Code Review一下子将它揪出。

行业大洗牌，来了

现在，安全公司和SaaS厂商都在哀嚎。

每年收5万美金的代码安全公司，还能活多久？

不是它们的技术不好，而是商业逻辑变了。

如果Anthropic可以用智能体团队，花20美元就能解决深度的业务逻辑安全审计，谁还会去买那些动辄几万美金、误报率还高得离谱的传统扫描器？

如果你还在手动Review几千行代码，或者还在为高昂的安全审计费买单，醒醒吧，时代变了。

今夜，AppSec行业的股票，可能真的要感受一下AI的寒意了。

本文来源：[新智元](#)

风险提示及免责声明

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时0元领
VIP会员·7天畅读卡 | 大师课·入门串讲

* 同一用户免费领取一次

扫码
免费领取



👍 239 ⭐ 收藏

分享到:



写评论

请发表您的评论



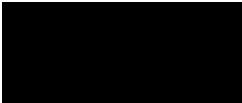
表情



图片

发布评论

2 条评论



正在加载 ..

